Studio Nx

백엔드 161 — POST /auth/password-reset/confirm

2026-10-14

백엔드 161 — `POST /auth/password-reset/confirm` (새 비밀번호로 바꾸기 라우터)

항목	내용
파일	`studionx/backend/app/api/v1/auth.py`의 `password_reset_confirm()`, 스키마 `app/schemas/auth.py`의 `PasswordResetConfirm`
작업	P1-28 비밀번호 찾기 (FR-118): 열두 번째 함수. **백엔드의 마지막 API**
작성	Claude (AI), 2026-10-15, 사용자 검토
이전	160 `POST /auth/password-reset/request`
시험	`tests/test_password_reset_service.py`의 15개 추가 (파일 전체 71개), 실제 앱과 실제 MySQL
다음	화면: 로그인 모달의 복구 화면(Password, Email 탭)과 `resetPassword.html`

1. 하는 일

로그인 없이 부르는 API입니다. 메일 링크의 토큰과 새 비밀번호를 받아 `reset_password()`(155번)를 부릅니다.

```
POST /api/v1/auth/password-reset/confirm
{ "token": "<메일 링크의 토큰>", "new_password": "Newpass1!" }

→ 204 No Content (본문 없음)
```

결과	언제
204	비밀번호가 바뀜
400 `INVALID_RESET_LINK` "This link is invalid or has expired."	링크가 틀렸거나, 만료됐거나, 이미 썼거나, 계정 상태가 맞지 않음 (**이유를 구분하지 않는 같은 문구**)
422 `VALIDATION_ERROR` + `details.new_password`	새 비밀번호가 규칙(FR-102)에 맞지 않음. **링크는 그대로 쓸 수 있음**
422	본문이 비었거나 필드가 없음, 토큰이 200자를 넘음

2. 코드

```
class PasswordResetConfirm(BaseModel):
    token: str = Field(min_length=1, max_length=200)
    new_password: str = Field(min_length=1, max_length=100)

@router.post("/password-reset/confirm", status_code=status.HTTP_204_NO_CONTENT,
             responses={400: {"model": ErrorResponse}, 422: {"model": ErrorResponse}})
def password_reset_confirm(data: PasswordResetConfirm, db: Db) -> None:
    password_reset_service.reset_password(db, data.token, data.new_password)
```

3. 결정과 이유

결정	이유
성공해도 자동 로그인을 하지 않음 (사용자가 정함)	메일 링크만 가진 사람이 곧바로 로그인되는 일을 막습니다. 재설정한 사람이 새 비밀번호로 직접 로그인합니다. 응답에 쿠키와 토큰이 없음을 시험으로 확인합니다
필드 이름 `new_password` (사용자가 정함)	비밀번호 변경(FR-107)과 같은 이름입니다
토큰은 길이만 제한하고 형식은 보지 않음	형식이 틀린 값과 없는 값을 구분하면 추측을 돕습니다. 어떤 값이든 서비스가 해시로 확인하고 같은 400으로 답합니다. 200자 제한은 터무니없이 긴 값이 해시 계산으로 가는 것을 막는 상한입니다
이 API에는 횟수 제한을 두지 않음	토큰이 256비트 무작위라 추측으로 맞힐 수 없습니다. 요청 API의 제한은 메일 폭탄을 막으려는 것이고, 이 API에서 틀린 토큰은 DB 조회 한 번으로 끝납니다. 필요해지면 서비스 쪽에 추가합니다
204	본문이 필요 없고, 화면은 성공하면 로그인 안내로 넘어가면 됩니다

4. 시험 (15개 추가, 파일 전체 71개 통과)

확인	결과
경로가 등록되고 204, 400, 422가 문서에 있음	✓
비밀번호가 바뀌고 204이며 본문이 없음	✓
자동 로그인을 하지 않음(쿠키 없음, 응답에 토큰 없음, 토큰 없이 `/users/me`는 401)	✓
재설정 뒤 새 비밀번호로 로그인되고 예전 비밀번호는 거부됨	✓
틀린 토큰은 400이고 문구와 본문이 정해진 그대로	✓
토큰은 한 번만 쓸 수 있음(같은 링크를 두 번 쓰면 두 번째는 400)	✓
만료된 토큰이 틀린 토큰과 **같은 응답**	✓
약한 비밀번호는 422이고 링크는 그대로 쓸 수 있음(고쳐서 다시 보내면 204)	✓
잘못된 본문 6종(비었음, 필드 없음, 빈 값, 200자 초과)은 422	✓ (6개)
전체 흐름: 이전 로그인이 유효 → 요청 API → 로그에 찍힌 링크의 토큰 → 재설정 → 이전 로그인이 **401**	✓

시험을 확인하는 시험. 일부러 틀리게 바꿔 시험이 잡는지 보았습니다.

바꾼 것	결과
상태 코드를 200으로	5개 실패
서비스 호출 제거	7개 실패
토큰과 비밀번호를 서로 뒤바꿔 넘김	5개 실패
토큰 길이 제한 제거	2개 실패
토큰 빈 값 허용	1개 실패

전체 pytest 816개 통과, `ruff` 통과.

5. 백엔드가 끝났습니다

비밀번호 찾기의 백엔드는 여기까지입니다. 함수 12개와 모델, 설정이 모두 시험으로 확인되었습니다.

번호	함수	하는 일
150	`hash_reset_token`	토큰 해시

번호	함수	하는 일
151	`generate_reset_token`	토큰 만들기
152	`create_reset_token`	토큰 저장 (이전 토큰 무효화)
153	`check_reset_rate_limit`	요청 횟수 제한
154	`request_password_reset`	요청 처리, 로그로 메일
155	`reset_password`	비밀번호 바꾸기
156	`issued_before_password_change`	이전 로그인 판단
157	`decode_token_with_iat`	토큰의 발급 시각 꺼내기
158	`get_current_user` 연결	액세스 토큰 거부
159	`/auth/refresh` 연결	재발급 거부, 쿠키 삭제
160	`POST …/request`	요청 API
161	`POST …/confirm`	확인 API

배포 전에 남은 일(각 문서에 적어 둔 것의 모음)

1. 실제 메일 발송(SMTP)을 붙이고 `MAIL_BACKEND`를 바꿔야 합니다. 그 전에는 배포에서 재설정이 동작하지 않습니다(안전한 쪽으로 실패).
2. 메일 발송을 응답 뒤의 백그라운드 작업으로 옮겨야 합니다(응답 시간 차로 가입 여부가 새지 않게).
3. `resetPassword.html`은 `#token=`을 읽은 뒤 주소창에서 지우고(`history.replaceState`), `Referrer-Policy: no-referrer`를 둬야 합니다.
4. 개인정보 처리방침(세 판)에 "재설정 메일 발송" 항목을 반영하고, 요청 횟수 제한이 서버 메모리 방식이라 서버를 여러 대로 늘리면 Redis로 옮겨야 합니다.
5. 이메일을 잊은 경우(FR-119)의 안내 메일은 아직 만들지 않았습니다(화면 작업과 함께 정합니다).